

# Legal Requirements Register (LRR) — NorthStream

## Cybersecurity Legislation and Compliance Assessment

**Course:** Cybersecurity Legislation and Compliance Assessments

**Student:** HASSANI Mohammad Salem

**Date:** January 29, 2026

**Instructor:** Asen Grozdanov

**Organization:** NorthStream Technologies

**Project:** Configuration Baseline Checklist for Web Server Infrastructure

---

## Executive Summary

NorthStream Technologies, a mid-sized Canadian infrastructure and logistics company based in Toronto, Ontario, operates across multiple provinces (Quebec, Alberta, and British Columbia) and manages sensitive data assets including personal identifiable information (PII) for approximately 5,000 employees, corporate financial records, and critical infrastructure SCADA (Supervisory Control and Data Acquisition) metadata.

This Legal Requirements Register (LRR) identifies the primary Canadian federal and provincial laws governing NorthStream's data protection and cybersecurity responsibilities. The analysis maps NorthStream's operational context to specific legislative requirements, establishes compliance obligations, and outlines the potential consequences of non-compliance. This report serves as the foundational documentation for NorthStream's Governance, Risk, and Compliance (GRC) framework and will form the first chapter of the final compliance assembly.

---

## Legal Requirements Register

### 1. PIPEDA — Personal Information Protection and Electronic Documents Act (Federal)

**Applicability:** Private-sector organizations handling personal information across Canada.

**Justification:** NorthStream processes PII of approximately 5,000 employees, including contact information, financial records, and employment history, triggering PIPEDA obligations.

**Key Sections:**

- **Accountability Principle:** Organizations must implement policies and practices to protect personal information throughout its lifecycle.
- **Safeguards Principle:** Appropriate security measures must be implemented to prevent unauthorized access, use, or disclosure.
- **Mandatory Breach Notification:** Organizations must notify individuals and the Privacy Commissioner when personal information is compromised.

**Compliance Implications:** NorthStream must establish privacy policies, conduct privacy impact assessments, implement access controls, and maintain breach notification procedures.

**Impact of Violation:** Regulatory investigations by the Office of the Privacy Commissioner (OPC), financial penalties, mandatory corrective action plans, and reputational damage.

---

## **2. Bill C-26 — Critical Cyber Systems Protection Act (CCSPA) (Federal)**

**Applicability:** Operators of critical infrastructure and critical cyber systems in Canada.

**Justification:** NorthStream utilizes SCADA systems supporting logistics and infrastructure operations, which fall under the definition of critical cyber systems essential to national infrastructure.

**Key Sections:**

- **Cybersecurity Program Requirement:** Organizations operating critical systems must develop and maintain a comprehensive cybersecurity program aligned with National Cyber Security Centre (NCCS) guidelines.
- **Incident Reporting Obligations:** Cyber incidents affecting critical systems must be reported to Canadian Centre for Cyber Security (CCCS) within mandated timeframes.
- **Security Assessments:** Regular security assessments and penetration testing are required to verify system resilience.

**Compliance Implications:** NorthStream must implement incident response plans (IRP), conduct regular security audits, maintain detailed incident documentation, and establish communication protocols with CCCS.

**Impact of Violation:** Federal enforcement actions, mandatory corrective measures, potential federal oversight of critical systems operations, and security directives.

---

## **3. Quebec Law 25 (Formerly Bill 64) — Protection of Personal Information**

**Applicability:** Organizations processing personal information within Quebec or serving Quebec residents.

**Justification:** NorthStream maintains active operations and employees in Quebec, requiring compliance with Quebec's enhanced privacy legislation.

**Key Sections:**

- **Appointment of Privacy Officer:** Organizations must designate a Privacy Officer responsible for compliance oversight and stakeholder communication.
- **Data Protection Impact Assessment (DPIA):** High-risk processing activities require formal assessments before implementation.
- **Enhanced Breach Notification:** Breaches affecting Quebec residents require notification within specific timeframes with detailed remediation information.
- **Individual Rights:** Expanded rights including access, rectification, deletion, and portability of personal data.

**Compliance Implications:** NorthStream must appoint a Privacy Officer, conduct DPIAs for new systems, implement granular access controls, and maintain detailed breach management procedures.

**Impact of Violation:** Quebec administrative fines up to \$25 million CAD or 4% of global revenue (whichever is greater), compliance orders, and potential criminal sanctions for intentional violations.

---

## 4. PIPA — Personal Information Protection Act (Alberta & British Columbia)

**Applicability:** Private-sector organizations operating in Alberta and/or British Columbia.

**Justification:** NorthStream conducts business and maintains employee records in both Alberta and British Columbia provinces.

**Key Sections:**

- **Reasonable Security Safeguards:** Organizations must implement and maintain security measures appropriate to the sensitivity of information held.
- **Breach Notification Requirements:** Individuals must be notified of breaches that create a reasonable risk of significant harm.
- **Accountability:** Organizations must demonstrate compliance through documentation and audit trails.
- **Access and Correction Rights:** Individuals have the right to request access to personal information and request corrections.

**Compliance Implications:** NorthStream must maintain encryption protocols, implement role-based access controls, establish breach assessment procedures, and document all security measures.

**Impact of Violation:** Provincial fines and compliance orders from provincial privacy commissioners (AB: Alberta Information and Privacy Commissioner; BC: Office of the Information and Privacy Commissioner for BC).

# Violation Impact Analysis

## Financial Consequences

- **Quebec Law 25:** Up to \$25 million CAD or 4% of global revenue
- **PIPEDA:** While federal penalties are administrative, remediation costs and reputational damage can exceed \$1 million for mid-sized organizations
- **Bill C-26:** Escalating penalties for continued non-compliance with security directives
- **PIPA (AB/BC):** Provincial fines ranging from \$100,000 to \$500,000+ per violation

## Operational Consequences

- Mandatory corrective action plans with CCCS oversight
- Suspension of critical system operations pending security improvements
- Mandatory third-party audits and ongoing monitoring
- System redesign and re-certification requirements

## Reputational and Business Impact

- Loss of stakeholder trust and client confidence
- Public disclosure of compliance failures
- Potential loss of contracts with government and regulated entities
- Difficulty obtaining cyber insurance or increased premiums

## Regulatory Consequences

- Formal investigations by OPC, CCCS, and provincial privacy commissioners
- Executive liability for intentional or negligent violations
- Enhanced regulatory scrutiny of all future operations
- Potential criminal prosecution in cases of deliberate misconduct

---

## Compliance Recommendations

NorthStream Technologies should immediately establish the following:

1. **Privacy Office:** Appoint a qualified Privacy Officer to oversee compliance with PIPEDA, Law 25, and PIPA.
2. **Incident Response Plan (IRP):** Develop a comprehensive IRP with specific protocols for CCCS notification (Bill C-26 compliance).
3. **Security Program:** Implement a cybersecurity program aligned with NIST Cybersecurity Framework and CCCS guidelines, with specific hardening for SCADA systems.

4. **Breach Management Procedure:** Create standardized procedures for breach detection, assessment, notification, and documentation.
  5. **Privacy Impact Assessments (DPIA):** Conduct DPIAs for all systems processing PII, particularly the employee database and financial records system.
  6. **Regular Audits:** Schedule annual third-party security audits and penetration testing to validate SCADA system integrity.
  7. **Documentation:** Maintain comprehensive records of all compliance activities, security measures, and incident responses for audit purposes.
- 

## Conclusion

NorthStream Technologies' multi-jurisdictional operations and management of sensitive data require compliance with a complex regulatory landscape. Failure to meet these obligations exposes the organization to substantial financial penalties, operational disruptions, and reputational damage. A structured GRC framework, led by a dedicated Privacy Officer and supported by robust cybersecurity practices, is essential to mitigate these risks and demonstrate good faith compliance to regulators and stakeholders.